

# CCPA and CPRA: What Is the Difference and How to Comply

## What Is the California Privacy Rights Act (CPRA), Formerly CCPA?

In January 2020, the California Consumer Privacy Act (CCPA) started a new era of regulatory compliance in the US, requiring businesses to do much more than update their privacy policies. The new California laws affect nearly 40 million California citizens and thousands of organizations they do business with.

In November 2020, voters approved the California Privacy Rights Act (CPRA) under the CCPA. The CPRA will take effect on January 1, 2023, giving California consumers more control over the personal information a company holds about them.

CPRA adds important new compliance obligations beyond CCPA, including new qualifying criteria for organizations, a new definition of Sensitive Personal Information (SPI), updates to existing rights, and new rights, such as the right to correct information.

This is part of a series of articles about [security compliance](#).

## Which Organizations Are Covered by the CPRA?

When the General Data Protection Regulation (GDPR) went into force in 2018, organizations processing personal data collected within the EU had to make special efforts to protect personal data and the privacy of data subjects. GDPR applies to an organization whether it operates within the EU or elsewhere, as long as it processes personal data of EU data subjects.

The scope of the California Privacy Rights Act (CPRA) is similar in that it applies to for-profit entities that process personal information of California residents, and meet one of three criteria:

- Businesses that share personally identifiable information (PI) of more than 100,000 consumers or households. This is an update to the CCPA's previous 50,000 consumer

threshold, making the law more friendly to small businesses.

- Companies with gross sales of \$25 million as of January 1 of the previous year.
- Companies that generate more than 50% of their total revenue by sharing or selling personal information they collect from users.

## What Is the Difference Between the CCPA and CPRA?

The CPRA expands on the CCPA (California Consumer Privacy Act) and provides further details on existing requirements. Thus, being familiar with the CCPA makes it easier to understand the CPRA.

The CCPA covers four main rights for Californians:

### **The right to know**

Californian citizens have a right to know what personal information companies collect and how they use or share it.

### **The right to delete**

Individuals can request companies delete their personal information unless the collected data is exempt for legal purposes or required to provide a service or complete a transaction. CCPA-exempted information includes medical records and credit history.

### **The right to opt out of data sales**

Consumers can prohibit the company from selling their personal information (PII) to a third party.

### **The right to non-discrimination**

The CCPA protects citizens from discrimination if they exercise their other rights. Businesses must not charge discriminatory prices or fail to deliver goods or services due to a customer's request to control personal data.

## What Does CPRA Introduce?

The CPRA does not completely replace the CCPA - it generally refines and expands its stipulations, providing practical guidelines to enforce the act's requirements. It updates some existing consumer and employee rights, such as establishing time frames for providing information to individuals.

The CPRA also updates qualifying requirements, applying to companies that "share" data, not just those that sell it. It also expands the legal actions individuals can take against businesses

that fail to comply with CCPA data security standards. For example, it permits lawsuits based on compromised login credentials.

The CRPA also introduces new requirements, such as annual assessments by the CPPA (California Privacy Protection Agency). This new agency must approve and report on these risk assessments. It also creates a new category for sensitive personal information (SPI) with stricter requirements.

The new rights codified by the CPRA include requesting businesses to update personal information, limiting the disclosure and use of SPI, and accessing information about automated decision-making. Individuals can also request that their data be exempt from automated decision-making technologies.

## **Steps from CCPA to CPRA Compliance**

### **Understand What Data Falls Under the CPRA's Expanded Scope**

CPRA's new regulations apply to more types of data. They include a new classification of sensitive personally identifiable information (SPI)—information such as social security numbers (SSN), driver's license numbers, biometric information, exact geographic location, racial and ethnic origin, and more. Organizations must accurately retrieve, classify, and manage this information in accordance with CPRA's data minimization and retention requirements.

### **Prepare for new Consumer and Employee Rights Requests**

The CCPA introduced new consumer rights for California citizens, including the right to know, the right to access, the right to erasure, the right to refuse to sell data, and the right to non-discrimination. CPRA now extends these rights to correction, portability, and restrictions on the disclosure of sensitive personal information, extending these rights to employees as well.

While many organizations implementing CCPA compliance programs have processes in place for handling consumer rights requests, employee rights requests pose some unique challenges. Increase. Granting privacy rights to employees requires organizations to parse and classify more unstructured data. This means the need for auto discovery and data remediation becomes even more critical with CRPA.

### **Update Policies for Retention & Sensitive Personal Information**

CPRA introduces new requirements for collection, use, and retention of sensitive personal information, limiting it to what is necessary to provide goods and services. Implementing these policies can be a challenge for organizations that work with large amounts of data.

## Perform Risk Assessments and Annual Cybersecurity Audits

The CPRA specifies that high-risk organizations—those that handle personal information or sensitive personal information - should perform periodic risk assessments similar to data protection impact assessments (DPIAs) required in the EU as part of the GDPR.

CPRA risk assessments are submitted to regulatory agencies, to ensure that if an organization performs data processing activities that pose significant risks to consumer privacy or safety, the activity is carried out with an appropriate level of protection to mitigate the risks.

In addition, CRPA requires organizations whose processing activities pose a significant risk to consumer privacy or security to conduct an annual, independent cybersecurity audit.

## CCPA and CPRA and HackerOne

As a California company, HackerOne complies with the requirements of CCPA and CPRA. Our customers can rest assured that data and personal information passing through or stored in our systems are managed with the utmost rigor and never sold. Gaining and maintaining the trust of our customers and users is part of our corporate DNA.

[Learn more about HackerOne Trust](#)

### Company

Leadership

Careers

Partners

Newsroom

### Knowledge

Center

Application Security

Penetration Testing

Cloud Security

### Resources

Blog

Documentation

Leaderboard

Partner Portal

Contacted  
by a  hacker?

Cybersecurity

Attacks

DevSecOps